

Aim: Case Study for SDLC & Threat Modelling choose a login module for any application

- a) Identify any 5 vulnerabilities and associated threats**
- b) Mention which security goals (CIA) can be at risk**
- c) Explain how this design controls vulnerability (which mechanism)**

Introduction to SDLC and Threat Modelling

Software Development Life Cycle (SDLC) is a systematic process for building software that ensures quality and correctness. Security should be integrated throughout all phases of SDLC:

- Requirements Phase: Define security requirements
- Design Phase: Create secure architecture
- Implementation Phase: Write secure code
- Testing Phase: Perform security testing
- Deployment Phase: Secure configuration
- Maintenance Phase: Patch and update

Threat Modelling is a structured approach to identifying, quantifying, and addressing security threats.

The STRIDE model is commonly used:

Threat Type	Description	Example
Spoofing	Impersonating someone else	Fake login credentials
Tampering	Modifying data	Changing user roles
Repudiation	Denying actions	Claiming not to have logged in
Information Disclosure	Exposing sensitive data	Password leakage
Denial of Service	Making system unavailable	Brute force attacks
Elevation of Privilege	Gaining unauthorized access	Becoming admin

Security Goals - CIA Triad

The CIA Triad represents three core security objectives:

- Confidentiality: Ensuring data is accessible only to authorized users
- Integrity: Maintaining data accuracy and trustworthiness
- Availability: Ensuring systems are accessible when needed

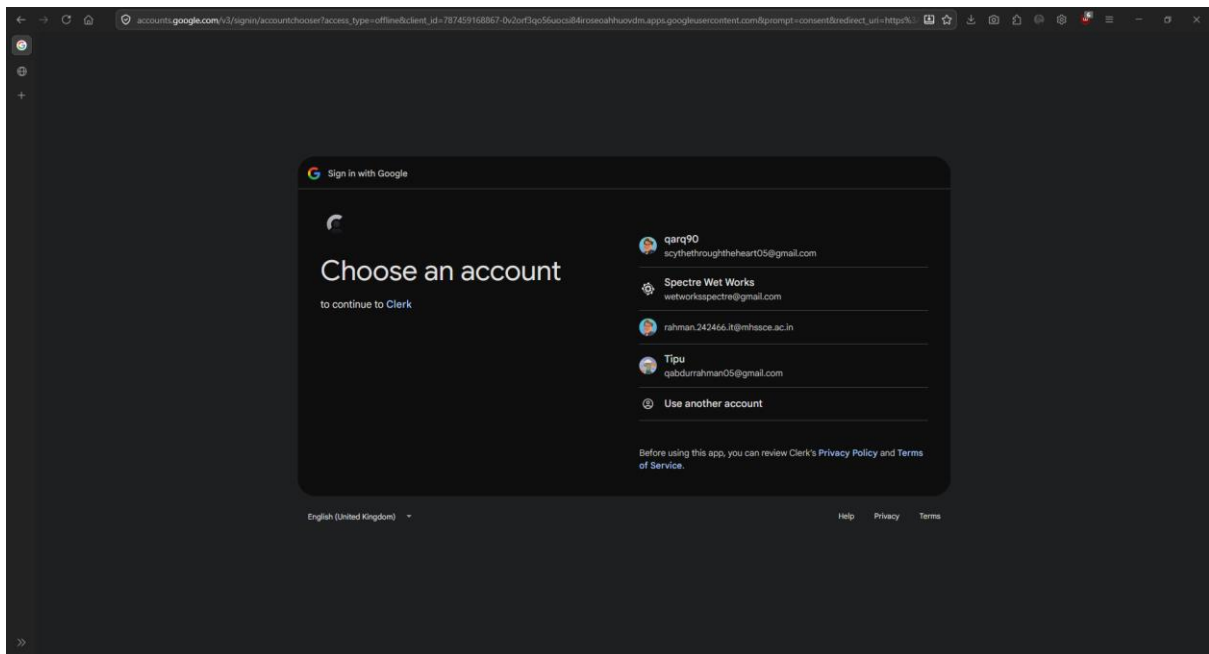
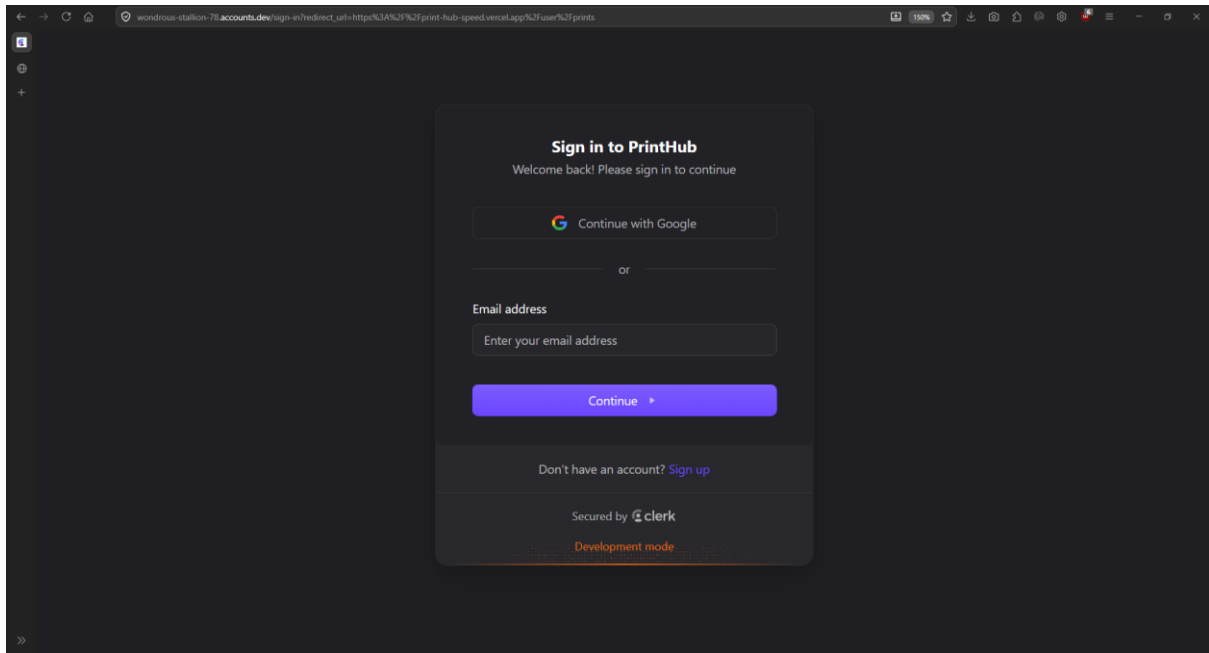
Case Study 1: PrintHub Login Module (Clerk + Google OAuth 2.0)

System Context: PrintHub utilizes Clerk as its managed authentication provider, incorporating OAuth 2.0 / OpenID Connect (OIDC) alongside Google Single Sign-On (SSO) with Multi-Factor Authentication (MFA).

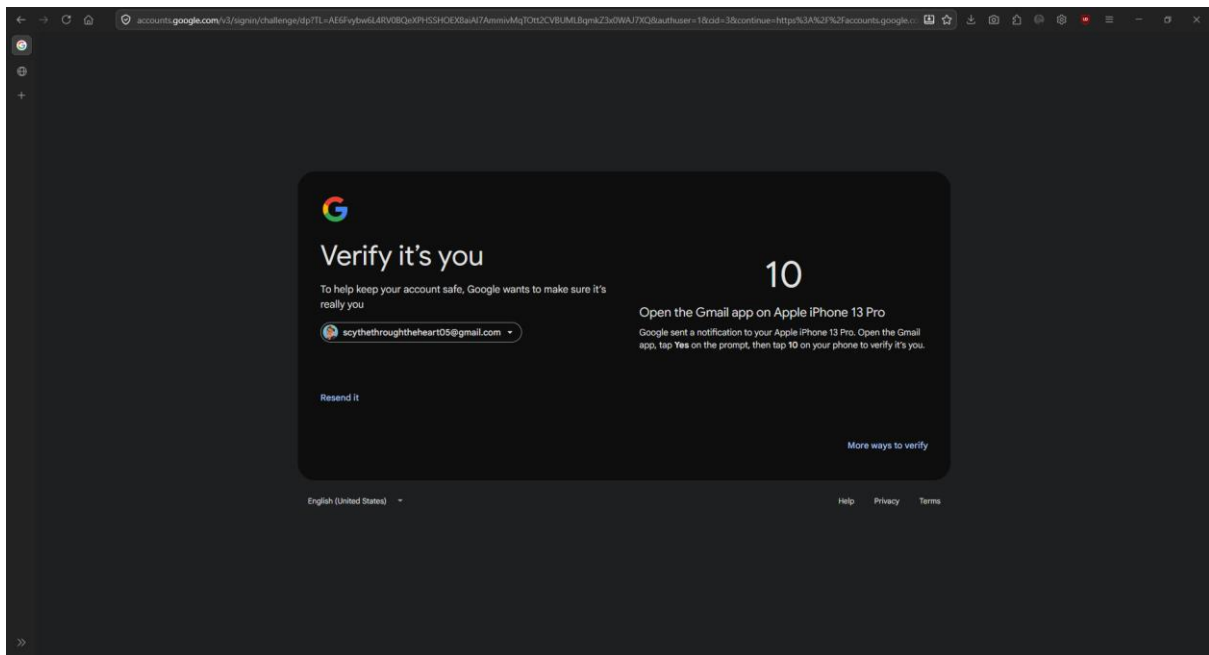
Vulnerability, Threat, and Mitigation Analysis:

No.	Identified Vulnerability	Associated Threat	Security Goals at Risk	Design Control / Security Mechanism
1	Insecure Redirect URI Validation	OAuth Authorization Code / Token Hijacking Attacker manipulates redirect URIs to steal authorization codes.	Confidentiality, Integrity	Strict Redirect URI Whitelisting & PKCE: Exact-match redirect URI enforcement combined with <i>Proof Key for Code Exchange (PKCE)</i> to mathematically bind auth codes to client verifiers.
2	Weak Credential Enforcement	Credential Stuffing & Password Reuse Attacks Automated scripts test stolen credentials against authentication endpoints.	Confidentiality, Integrity	Delegated OAuth & Mandatory 2FA/MFA: Delegated identity verification via Google SSO utilizing out-of-band push notifications (Google Prompt / OTP) before issuing session tokens.
3	Cross-Site Request Forgery (CSRF)	Session Binding & Account Takeover Forcing an authenticated victim to attach their session to an attacker's account.	Integrity	State Parameter & Cryptographic Nonces: Mandatory validation of a cryptographically secure, unpredictable state parameter on each OAuth callback.
4	Insecure Session Storage	Cross-Site Scripting (XSS) Token Theft Malicious scripts extracting session tokens stored in browser local storage.	Confidentiality, Integrity	HTTP Only, Secure Cookies & Short-Lived JWTs: Storing access tokens in memory and refresh tokens in HTTP Only, Secure, Same Site=Lax/Strict cookies unreachable via JavaScript APIs.
5	Endpoint Rate Limiting Absence	Brute-Force & Denial of Service (DoS)	Availability, Confidentiality	Automated Rate Limiting & Bot Protection: IP-based throttling, progressive delay backoffs, and CAPTCHA

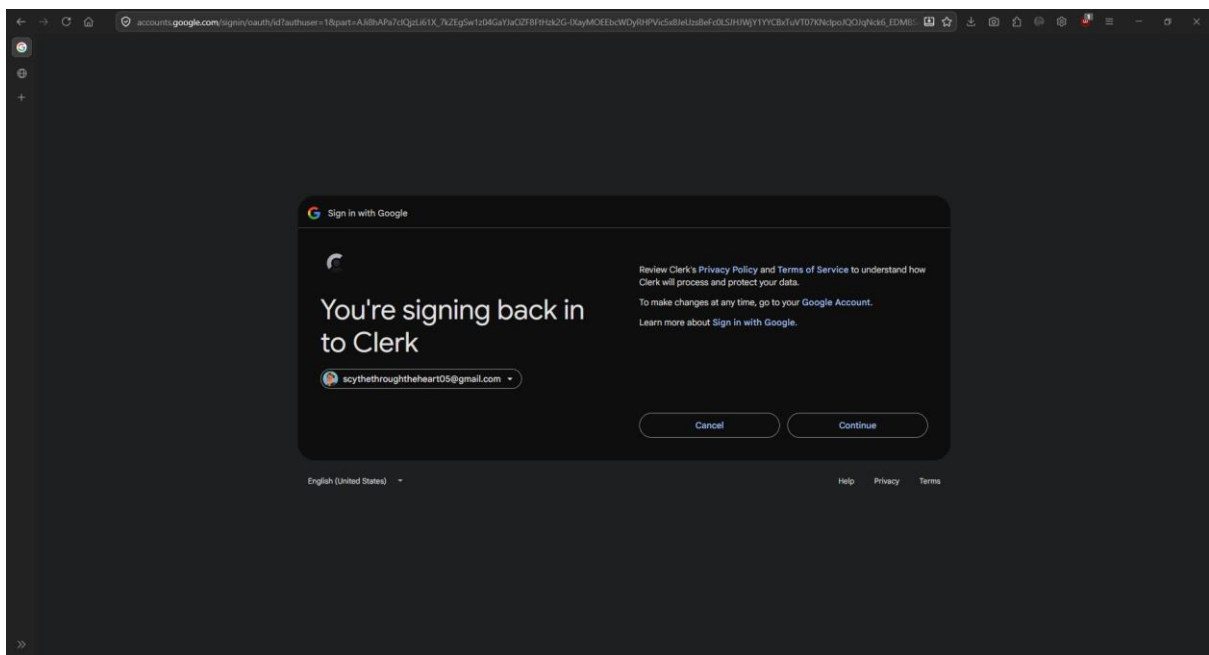
		Automated botnet traffic flooding authentication/token endpoints.		challenges integrated within Clerk infrastructure.
--	--	---	--	--



Multi-Account Selector UI: Displaying stored user identities during the OAuth 2.0 authorization code flow.



Multi-Factor Authentication (MFA): Google Prompt enforcing step-up verification on an authenticated mobile device.



Initial OAuth Redirect: Google Account Sign-in UI initiating authentication callback for Clerk integration.

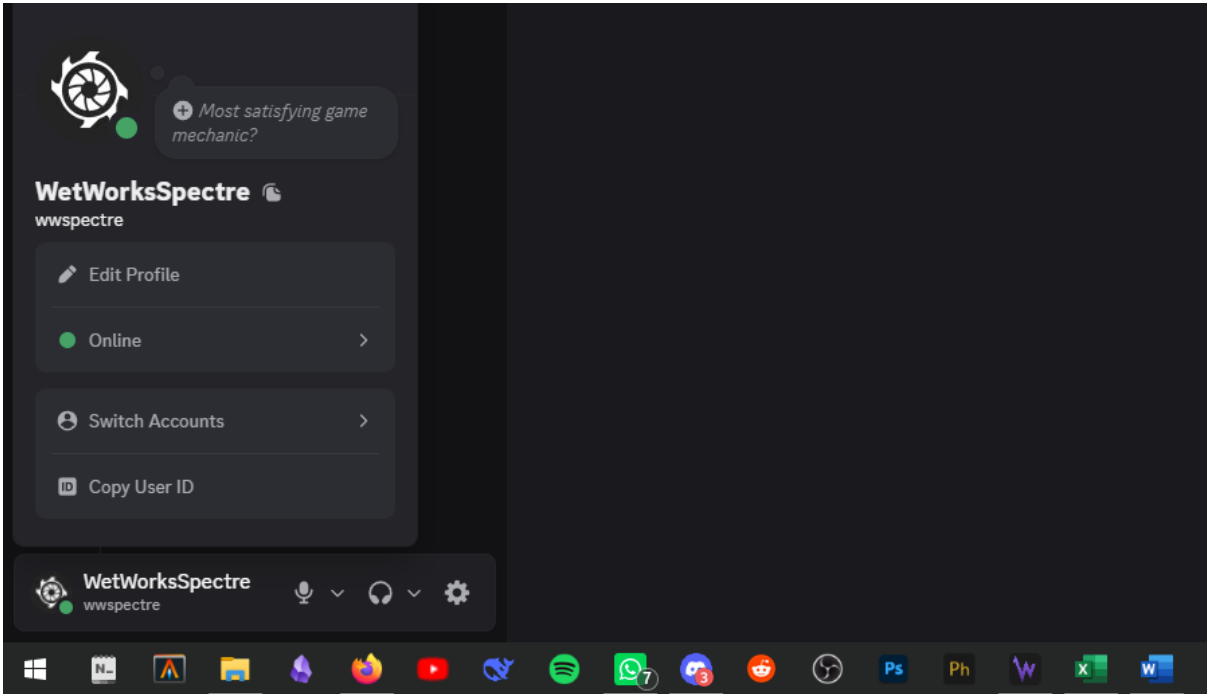
Case Study 2: Discord Multi-Account & Account Switcher Module

System Context: Discord allows concurrent multi-account session management, permitting users to add, switch, and maintain multiple authenticated profiles within desktop, web, and mobile client interfaces.

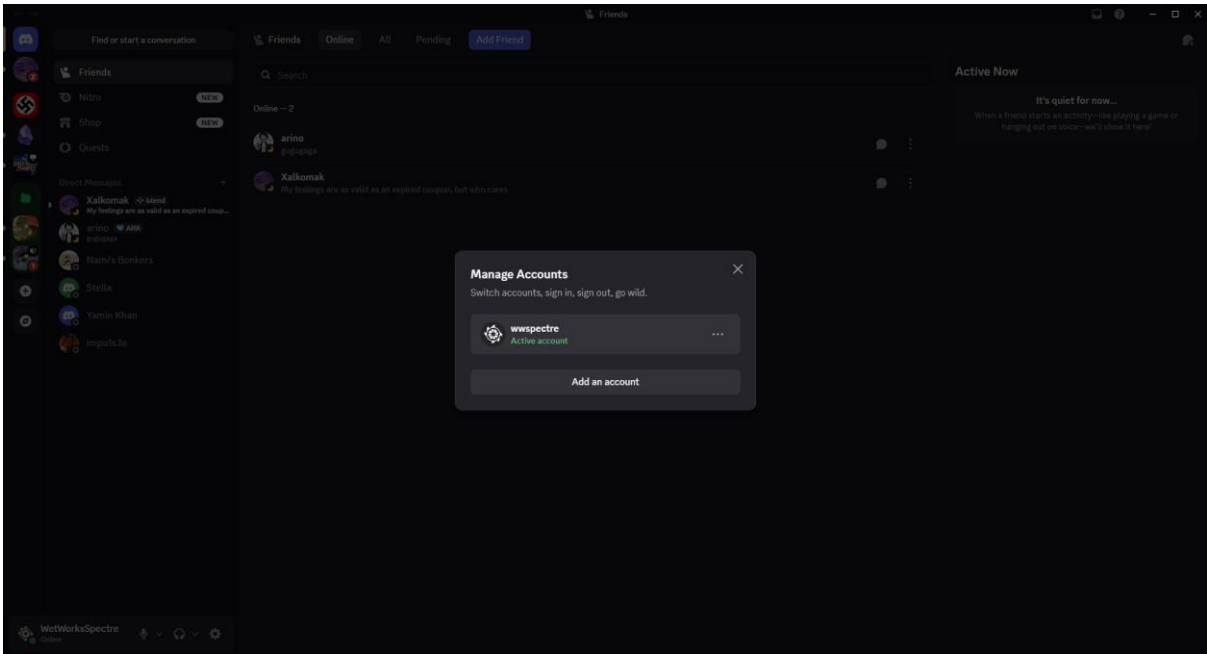
Vulnerability, Threat, and Mitigation Analysis:

No.	Identified Vulnerability	Associated Threat	Security Goals at Risk	Design Control / Security Mechanism
1	Unencrypted Token Persistence on Disk	Local Token Theft / Malware Extraction Local spyware or compromised processes reading raw session tokens from disk storage.	Confidentiality, Integrity	OS-Level Keyring / Encrypted Storage: Storing cached authentication tokens using native system APIs (such as Windows DPAPI or macOS Keychain) rather than plaintext files.
2	Stale Multi-Account Sessions	Unauthorized Access via Abandoned Devices Switched-out profiles remaining active indefinitely on shared or unattended endpoints.	Confidentiality	Centralized Session Dashboard & Remote Revocation: Real-time token revocation mechanisms allowing remote session termination across switched account profiles.
3	Insufficient Context Isolation	Cross-Account Data / Token Contamination Flaws in application memory isolation leaking authorization tokens between switched accounts.	Confidentiality, Integrity	Isolated Execution Contexts: Maintaining strict sandboxing and segregated memory spaces/storage buckets for each active user profile state.
4	Static Session Authorization Headers	Replay Attacks Intercepted auth tokens reused to execute unauthorized actions across switched accounts.	Confidentiality, Integrity	Dynamic Token Rotation & Ephemeral Tokens: Re-evaluating profile authorization and rotating tokens when switching between active profile contexts.
5	Missing Step-Up Authentication	Privilege Escalation on Switched Accounts Executing destructive actions (e.g., deleting	Integrity	Step-Up Authentication (Sudo Mode): Requiring password re-entry or 2FA verification before permitting high-privilege configuration changes

		servers, modifying passwords) without secondary verification.		within an active account session.
--	--	---	--	-----------------------------------



Interface showing concurrent multi-account session management and profile switching control.



Active Profile Context Menu: Displaying active user status alongside the "Switch Accounts" interface trigger.